PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Pilotage et stratégie de la supervision de sécurité

03-940 ANSSI - La supervision de sécurité, clés de décision et pilotage d'un projet — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La supervision de sécurité englobe la détection, la qualification d'un incident et le choix de la réaction appropriée.
2. La construction de la supervision doit être itérative en s'appuyant sur un MVP pour commencer à détecter au plus vite.
3. Le budget de supervision doit être considéré comme un investissement pluriannuel incluant un coût de construction et un coût d'entretien.

La collection de l'ANSSI

Notion	À retenir
Collection en trois volets	Comprend un volet **stratégique** (**ANSSI-GP-112**), un volet **opérationnel** et un volet **technique**. Les deux premiers datent du **25 juillet 2025**.
Place de la supervision	Participe au **traitement des incidents** (**renseignement sur la menace** et **réponse à incidents**). Inclut la **détection**, la **qualification** et le **choix de la réaction**.

Pourquoi et comment superviser

Notion	À retenir
Le principe	Attaque décomposée en **étapes unitaires** (EBIOS RM, ISO 27005, Cyber Kill Chain, MITRE ATT&CK) laissant des **traces** : détection avant l'atteinte des objectifs. Comparée aux contrôles d'identité et de bagages avant un vol.
Bénéfices et cadre	Passage du mode **réactif** au mode **proactif**. Cadre : **loi pour la confiance dans l'économie numérique**, **loi de programmation militaire**, **directive NIS** et **RGPD**.
L'analyse	1. **Automatisée** (capteurs/outils) : identifie les événements. 2. **Manuelle** (analystes) : qualifie les incidents par recoupement, pivot, corrélation et investigation.

Prérequis et acteurs de la supervision

Notion	À retenir
Quatre prérequis	**Maîtrise technique** (ex: guide d'hygiène), **connaissance des risques**, **moyens techniques dédiés** et **moyens humains/organisation adaptés** (même en cas d'externalisation).
L'équipe et ses deux cercles	**Analystes** (centre) : traitent les alertes. **1er cercle** : renseignement (matière première) et réponse à incidents. **2e cercle** : gouvernance (décision/finance) et gestion opérationnelle (périmètre).

Construction de la supervision

Notion	À retenir
Quand démarrer	Investir **au plus vite**, avant la prochaine attaque. Effectuer un **assainissement préalable** si le système n'est pas conforme au **guide d'hygiène informatique**.
La construction itérative	S'appuyer sur un **MVP** (périmètre restreint, qualité réduite) puis s'améliorer via **6 étapes** : cadrer, vérifier les données, concevoir la stratégie, déployer, mettre sous supervision et valider.
Le budget	Considérer comme un **investissement pluriannuel** incluant un **coût de construction** et un **coût d'entretien**. L'**achat ponctuel** d'un produit est insuffisant.

Composantes et enjeux du projet

Notion	À retenir
Les composantes	Comprend : analystes, données, stratégie, processus métier/support, règles de gestion/détection et un **SI de supervision**. Les processus incluent la **veille**, la **gestion des règles**, les **analyses**, la **qualification/signalement** et le **suivi**.
Les enjeux	Comporte des enjeux **stratégiques, projet, humains, métier, techniques, juridiques et cyber**. Le **SI de supervision** doit être sécurisé (**brique de sécurité** et **cible de choix**). La **mutualisation** (interne ou prestataire) crée des **risques spécifiques**.

Les dix recommandations du pilotage

- **R1** Connaître le système (risques, technologies, architecture)
- **R2** Le **préparer** (hygiène, défense en profondeur) avant de le superviser
- **R3** Commencer avec les **moyens en place**
- **R4** Démarche **ascendante**, sources diversifiées progressivement
- **R5** Priorité aux **postes de travail**, puis bordure, services exposés, annuaire
- **R6** Démarche **frugale** face au volume de données
- **R7** Progresser **par petits pas**
- **R8** Ressources cohérentes avec les ambitions (course de fond)
- **R9** Gérer l'**incertitude** : tests réguliers, red team
- **R10** Cultiver la **confiance** (transparence, indicateurs partagés)

Pièges et confusions

⚠ Réduire la supervision à la seule détection
⚠ Superviser un système qui ne respecte pas l'hygiène informatique
⚠ Croire que l'absence d'alerte prouve l'absence d'attaque
⚠ Confondre les faux positifs qui surchargent les analystes et les faux négatifs qui laissent passer les attaques

Sigles et définitions

SOC	Centre opérationnel de sécurité qui assure la supervision
EDR	Solution de détection et de réponse installée sur les équipements terminaux
MVP	Première version permettant de commencer à détecter au plus vite
Étape unitaire	Action élémentaire d'une cyberattaque laissant des traces spécifiques
Événement de sécurité	Événement significatif identifié automatiquement à partir de l'activité du système
Incident de sécurité	Événement vérifié et qualifié par un analyste
Règle de détection	Déclinaison technique de la stratégie de supervision
Faux positif / faux négatif	alerte sans activité malveillante (surcharge les analystes) / activité malveillante non détectée

Auto-test

1. Quels sont les trois éléments que la supervision doit permettre de réaliser ?
2. Quelle est la différence entre un événement de sécurité et un incident de sécurité ?
3. Quels sont les deux types de coûts à inclure dans le budget de supervision ?
4. Qu'est-ce qu'un faux positif ?
5. Quels sont les deux cercles de l'équipe de supervision ?

Réponses : **1.** La détection, la qualification et le choix de la réaction. · **2.** L'événement est identifié automatiquement, l'incident est vérifié et qualifié par un analyste. · **3.** Un coût de construction et un coût d'entretien. · **4.** Une alerte levée alors qu'il n'y a pas d'activité malveillante. · **5.** Le 1er cercle (renseignement et réponse à incidents) et le 2e cercle (gouvernance et gestion opérationnelle).

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.